

eVDP — Messagerie et clés PGP

Oct 1, 2026 · @Dev One

Vue d'ensemble

eVDP envoie ses emails par SMTP et chiffre le contenu sensible avec des clés PGP publiques. Aucune clé privée n'est stockée en clair côté serveur.

- **Messagerie** : notifications, vérification d'adresse, réinitialisations et rappels partent du conteneur `evdp-web` et des tâches Celery (`evdp-worker` , `evdp-beat`). Par défaut, tout est capturé par Mailpit ; en production, on pointe vers un vrai relais SMTP.
- **PGP** : la clé publique nationale chiffre les détails sensibles d'un signalement dans le navigateur du signaleur. La paire est générée dans eVDP, sur le poste du gestionnaire ; la clé privée est remise à l'équipe nationale chiffrée par un code à usage unique, et l'équipe déchiffre dans son navigateur.

Prérequis : la pile Docker démarrée (`docker compose up -d`), l'accès au fichier `.env` du serveur et, pour PGP, un compte super administrateur ou coordinateur national. GnuPG n'est plus nécessaire.

Configurer le serveur de messagerie

Tout se règle dans `.env` : `docker-compose.yml` lit ces variables et n'a pas à être modifié. Sans réglage, les emails partent vers Mailpit (`evdp-mailpit:1025`).

Variable	Rôle	Développement (Mailpit)	Production (exemple)
<code>EMAIL_BACKEND</code>	Moteur d'envoi Django	<code>django.core.mail.backends.smtp.EmailBackend</code>	identique
<code>EMAIL_HOST</code>	Serveur SMTP	<code>evdp-mailpit</code>	<code>smtp.votre-domaine.bf</code>
<code>EMAIL_PORT</code>	Port SMTP	<code>1025</code>	<code>587</code>
<code>EMAIL_USE_TLS</code>	STARTTLS	<code>False</code>	<code>True</code>
<code>EMAIL_USER</code>	Identifiant SMTP	vide	<code>no-reply@evdp.bf</code>
<code>EMAIL_PASSWORD</code>	Mot de passe SMTP	vide	mot de passe du compte
<code>DEFAULT_FROM_EMAIL</code>	Expéditeur affiché	<code>evdp <no-reply@evdp.bf></code>	adresse autorisée par le relais
<code>SITE_BASE_URL</code>	Base des liens dans les emails	<code>http://localhost:8090</code>	<code>https://evdp.votre-domaine.bf</code>

En développement : Mailpit

1. Laisser les valeurs par défaut de `.env.example`.

2. Démarrer avec la surcharge dev pour exposer l'interface : `docker compose -f docker-compose.yml -f docker-compose.dev.yml up -d`.
3. Ouvrir `http://127.0.0.1:8025` : chaque email envoyé par eVDP y apparaît. Aucun ne sort vers Internet.

En production : relais SMTP réel

1. Obtenir un compte SMTP authentifié auprès du fournisseur de messagerie (port 587 avec STARTTLS recommandé).
2. Renseigner dans `.env` les variables de la colonne Production. `DEFAULT_FROM_EMAIL` doit être une adresse que le relais accepte d'envoyer.
3. Mettre `SITE_BASE_URL` à l'adresse publique exacte de l'instance, sinon les liens des emails sont faux.
4. Configurer SPF, DKIM et DMARC pour le domaine expéditeur, pour éviter le classement en spam.
5. Recréer les conteneurs pour qu'ils lisent le nouveau `.env` : `docker compose up -d`. Un simple `restart` ne suffit pas.

Le service Mailpit peut rester démarré en production : il n'est plus utilisé dès que `EMAIL_HOST` pointe ailleurs.

Tester l'envoi

```
docker compose exec evdp-web python manage.py sendtestemail
adresse@exemple.bf
```

En dev, le message doit apparaître dans Mailpit ; en production, dans la boîte du destinataire. Une erreur s'affiche directement dans la console si le serveur refuse la connexion ou l'authentification.

Créer, publier et remettre les clés PGP

Tout se fait dans eVDP, depuis le navigateur : la paire de clés est générée sur le poste du gestionnaire et seule la clé publique part au serveur. La clé privée ne transite par eVDP que chiffrée par un code de remise qu'eVDP ne reçoit jamais.

Rôle	Ce qu'il peut faire
Super administrateur, coordinateur national	Générer, publier, remettre et annuler une remise (capacité <code>MANAGE_PGP_KEYS</code>)

Rôle	Ce qu'il peut faire
Agent de triage, analyste CSIRT, coordinateur	Recevoir la clé privée et déchiffrer les dossiers
Auditeur, comptes d'organisation	Aucun accès à la clé privée

1. Générer la paire

1. Menu Administration → **Clé PGP nationale** (`/pgp/cle-nationale/`).
2. Carte « Générer une nouvelle paire » : vérifier le nom et l'adresse, choisir la validité (1 à 3 ans), saisir deux fois une phrase secrète de 12 caractères au moins.
3. Cliquer **Générer dans mon navigateur**. L'empreinte et la date d'expiration s'affichent.
4. Cliquer **Télécharger la clé privée** puis **Télécharger le certificat de révocation**, et ranger les deux fichiers hors ligne, en lieu sûr.

2. Publier la clé publique

Cocher « J'ai enregistré la clé privée et le certificat de révocation », puis cliquer **Publier la clé publique**. Le bouton reste inactif tant que la clé privée n'a pas été téléchargée.

La clé est aussitôt servie sur `/pgp-key.asc` et annoncée dans `/.well-known/security.txt`. L'ancienne clé passe dans l'historique, et la publication est tracée dans le journal d'audit (`PGP_KEY_PUBLISHED`).

3. Remettre la clé privée à un destinataire

1. Carte « Remettre la clé privée » : choisir le destinataire.
2. Charger le fichier de clé privée (`.asc`). Juste après une génération, ce champ peut rester vide : la clé générée sur la page est utilisée.
3. Cliquer **Préparer la remise**. Le navigateur vérifie que la clé correspond à la clé publiée et qu'elle est protégée par une phrase secrète, puis la chiffre avec un code aléatoire.
4. Noter le **code de remise** affiché (24 caractères, `XXXX-XXXX-XXXX-XXXX-XXXX-XXXX`) : il ne sera plus jamais affiché.
5. Transmettre le code et la phrase secrète de la clé par téléphone ou en personne, jamais par email.

Le destinataire reçoit une notification et un email avec le lien de récupération. Le tableau « Remises » suit chaque remise (En attente, Récupérée, Annulée, Expirée) ; **Annuler** efface aussitôt une remise en attente.

4. Récupérer la clé (destinataire)

1. Ouvrir le lien reçu (/pgp/remise/<identifiant>/), connecté avec son propre compte.
2. Saisir le code de remise, puis cliquer **Récupérer ma clé**.
3. La clé est déchiffrée dans le navigateur et enregistrée sur le poste (evdp-national-...-PRIVEE.asc). Elle est alors effacée du serveur.

Règle de remise	Valeur
Validité d'une remise	24 heures
Essais de code	5, puis la remise est effacée
Récupération	Une seule fois, par le destinataire uniquement
Ce que le serveur conserve	La clé chiffrée, jamais le code ; effacée après récupération, annulation ou expiration
Trace d'audit	PGP_KEY_DELIVERY_CREATED , PGP_KEY_DELIVERY_RETRIEVED , PGP_KEY_DELIVERY_REVOKED

5. Déchiffrer un signalement

Dans la fiche du dossier, charger le fichier .asc reçu et saisir la phrase secrète de la clé, puis déchiffrer le bloc et les pièces .gpg . La clé n'est ni envoyée ni conservée ; « Oublier la clé » l'efface de la page.

6. Rotation avant expiration

eVDP alerte les gestionnaires 30 jours avant l'expiration. Générer et publier une nouvelle paire (étapes 1 et 2), puis la remettre à chaque destinataire. Garder l'ancienne clé privée : elle reste nécessaire pour déchiffrer les signalements antérieurs à la rotation.

Autres cas

- **Clé générée avec GnuPG** : `gpg --quick-generate-key "CSIRT National ANSSI-BF <vdp@anssi.bf>" ed25519 cert,sign 2y`, puis `gpg --quick-add-key <EMPREINTE> cv25519 encr 2y` et `gpg --armor --export <EMPREINTE>` . Coller le bloc dans l'encart « Publier une clé générée ailleurs (GnuPG) ». Le fichier de `gpg --armor --export-secret-keys` peut ensuite servir à une remise.
- **Clés des organisations et des programmes** : une organisation, un contact de sécurité ou un programme peut avoir sa propre clé publique (champ « clé publique PGP » de sa fiche), soumise aux mêmes contrôles.

- **Repli par `.env`** : `PGP_PUBLIC_KEY` n'est lue que si aucune clé n'est publiée dans l'application (une seule ligne, sauts de ligne échappés en `\n`).

Vérifications et dépannage

Symptôme	Cause probable	Correction
Aucun email reçu en production	<code>.env</code> modifié mais conteneurs non recréés	<code>docker compose up -d</code> , puis <code>sendtestemail</code>
<code>SMTPAuthenticationError</code>	Identifiant ou mot de passe refusé	Vérifier <code>EMAIL_USER</code> / <code>EMAIL_PASSWORD</code> ; certains fournisseurs exigent un mot de passe d'application
Délai dépassé à la connexion	Port 587 bloqué en sortie, ou mauvais couple port / TLS	Tester <code>587</code> + <code>EMAIL_USE_TLS=True</code> ; ouvrir le pare-feu sortant
Emails en spam	SPF, DKIM ou DMARC absents	Configurer le DNS du domaine de <code>DEFAULT_FROM_EMAIL</code>
Liens des emails vers une mauvaise adresse	<code>SITE_BASE_URL</code> vide ou erroné	Mettre l'URL publique exacte, puis recréer les conteneurs
« Ce bloc contient une clé privée »	Export fait avec <code>--export-secret-keys</code>	Réexporter avec <code>gpg --armor --export</code>
« Aucune clé publique OpenPGP v4 ou v6 »	Bloc tronqué ou mauvais fichier collé	Coller tout le fichier <code>.asc</code> , lignes BEGIN et END comprises
Clé refusée car expirée	Date d'expiration dépassée	<code>gpg --quick-set-expire <EMPREINTE> 2y '*'</code> , réexporter, republier
<code>/pgp-key.asc</code> répond 404	Aucune clé publiée ni repli <code>.env</code>	Publier la clé depuis Administration → Clé PGP nationale
« Cette clé privée ne correspond pas à la clé nationale publiée »	Fichier d'une ancienne clé chargé pour la remise	Charger la clé privée de la paire actuellement publiée

Symptôme	Cause probable	Correction
« Code incorrect. Il reste N essai(s) »	Faute de saisie du code de remise	Ressaisir le code ; tirets et casse sont ignorés
« Cette remise n'est plus disponible »	Remise expirée (24 h), annulée, déjà récupérée ou 5 essais épuisés	Le gestionnaire prépare une nouvelle remise, avec un nouveau code

Pour contrôler la clé réellement servie : télécharger `/pgp-key.asc` , puis `gpg --show-keys evdp-national.asc` et comparer l'empreinte avec celle de l'équipe.